PLAN INTEGRAL DE SEGURIDAD
PLATZI WALLET EN AWS

Documento de continuidad del proyecto: enfoque viable, profesional, progresivo y explicativo

Proyecto	Platzi Wallet
Entregable	Plan de seguridad y hardening sobre AWS
Arquitectura base	Laravel monolito modular en ECS Fargate + RDS MySQL + Redis + S3 + SQS
Propósito	Proteger una wallet cloud-ready sin perder continuidad ni viabilidad de implementación

1. Resumen ejecutivo

Este documento define el plan integral de seguridad de Platzi Wallet sobre la arquitectura AWS seleccionada en las etapas previas del proyecto. La meta no es reinventar el sistema, sino endurecerlo de forma realista y progresiva sobre una base ya aprobada: cliente web/PWA, distribución con CloudFront y S3, entrada segura mediante ALB/API, backend Laravel desplegado en ECS Fargate, persistencia en Amazon RDS MySQL, caché en ElastiCache Redis, almacenamiento en S3 y procesos asíncronos con SQS.

El plan combina controles preventivos, detectivos y correctivos. Incluye threat modeling STRIDE, principios de mínimo privilegio y Zero Trust, cifrado en tránsito y reposo, gestión de secretos, monitoreo, auditoría, cumplimiento y respuesta a incidentes. La propuesta busca una línea profesional y defendible, pero también viable: se priorizan controles que sí encajan con la arquitectura elegida y con una implementación progresiva del proyecto.

2. Alcance, objetivos y supuestos

Objetivos de seguridad del plan:

- Proteger la confidencialidad, integridad y disponibilidad de datos personales, credenciales, saldos, transacciones y evidencias.
- Reducir la superficie de ataque en identidad, red, aplicación, datos y operación cloud.
- Cumplir con los dominios técnicos más importantes para una wallet: control de acceso, cifrado, trazabilidad, respaldo y respuesta a incidentes.
- Soportar continuidad operativa sin introducir una complejidad inviable para el proyecto.
- Dejar una línea base clara para endurecimiento adicional y madurez operativa posterior.

Supuestos de trabajo:

- AWS se mantiene como nube objetivo.
- La aplicación se conserva como monolito modular Laravel y no evoluciona todavía a microservicios completos.
- Las tarjetas son procesadas por pasarela externa; la aplicación no almacena PAN completo.
- El despliegue objetivo usa ECS Fargate, RDS MySQL Multi-AZ, ElastiCache Redis, S3, SQS, CloudFront, ALB, Route 53, ACM, KMS, CloudTrail y CloudWatch.
- La seguridad debe ser fuerte, pero compatible con una operación académica-profesional viable.

3. Activos críticos y superficie de ataque

Los activos priorizados para la seguridad de Platzi Wallet son los siguientes:

Activo	Descripción	Impacto si se compromete	Prioridad
Credenciales y sesiones	JWT, refresh tokens, sesiones de usuario y credenciales administrativas	Toma de cuenta, fraude, acceso no autorizado	Alta
Datos transaccionales	Saldos, movimientos, comprobantes y conciliaciones	Fraude, pérdida de integridad financiera, reclamaciones	Alta
Datos personales / KYC	Datos de identidad, contacto y evidencias documentales	Sanción regulatoria, daño reputacional	Alta
Secretos y llaves	Claves API, secretos de BD, tokens de terceros, claves KMS	Escalada de acceso y compromiso sistémico	Alta
Infraestructura y pipeline	Cuenta AWS, roles IAM, imágenes ECR y workflows CI/CD	Compromiso del despliegue y persistencia del atacante	Alta
Logs y auditoría	CloudTrail, CloudWatch, alertas y evidencias operativas	Pérdida de trazabilidad y dificultad de respuesta	Media-Alta

Figura 1. Arquitectura segura objetivo de Platzi Wallet en AWS.

4. Modelo de responsabilidad compartida

La nube no elimina la responsabilidad del proyecto; la redistribuye. AWS protege la seguridad OF the cloud, mientras que Platzi Wallet protege la seguridad IN the cloud.

Responsabilidad principal de AWS	Responsabilidad principal de Platzi Wallet
Infraestructura física, datacenters, backbone, hipervisor, aislamiento de tenants, durabilidad y parches base de servicios administrados.	Clasificación de datos, IAM, MFA, configuración segura, buckets, base de datos, código, dependencias, secretos, monitoreo y auditoría.

5. Principios de seguridad aplicados

Identidad y acceso

- MFA para usuarios administrativos y cuenta root.
- Uso de roles IAM y task roles de ECS en lugar de access keys persistentes.
- Separación de ambientes y funciones: desarrollo, producción y auditoría.
- OIDC para CI/CD con GitHub Actions y credenciales temporales.

Cifrado y protección de datos

- TLS 1.3 entre cliente y plataforma.
- Cifrado en reposo para RDS, S3, snapshots y secretos con KMS.
- Parámetros y secretos fuera del código fuente.
- Conexiones de aplicación a base de datos con SSL/TLS forzado.

Red y perímetro

- ALB expuesto únicamente por HTTPS.
- Subred pública solo para balanceo y NAT; aplicación y datos en capas privadas/aisladas.
- Security Groups por mínimo privilegio.
- WAF con reglas administradas OWASP y rate limiting.

Observabilidad y respuesta

- CloudTrail multi-región activo.
- Logs centralizados en CloudWatch con retención definida.
- GuardDuty, Security Hub e Inspector para detección y priorización.
- Runbooks y playbooks para incidentes críticos.

6. Threat modeling STRIDE

Se aplicó STRIDE sobre los componentes críticos del sistema. La evaluación busca amenazas concretas y controles viables, no una lista abstracta sin aplicación operativa.

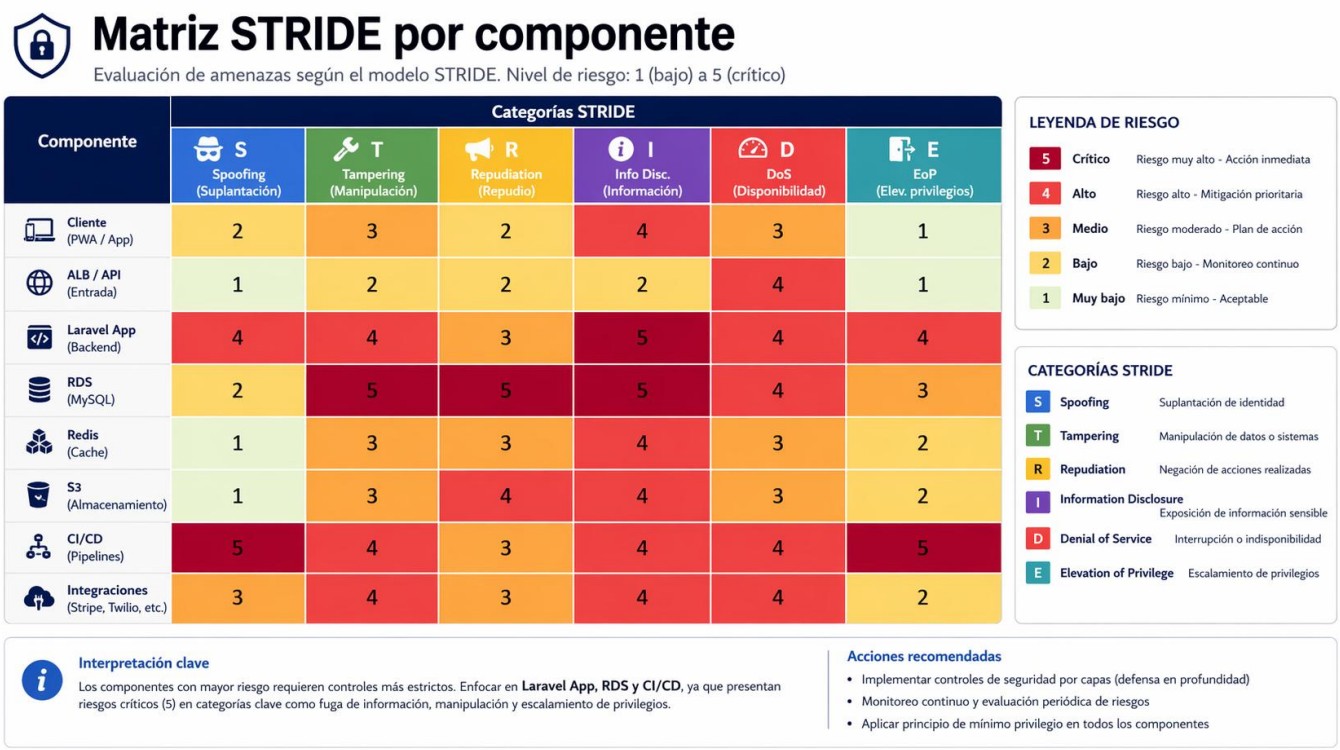

Figura 2. Matriz STRIDE por componente con severidad relativa.

Componente	Amenaza	Tipo STRIDE	Impacto	Control principal
Cliente / login	Robo de sesión o phishing	Spoofing	Acceso fraudulento a cuentas	MFA, expiración de sesión, detección de anomalías y comunicación segura.
ALB / entrada	Abuso masivo de peticiones	DoS	Degradación del servicio y pagos fallidos	WAF, rate limiting, Shield Standard y autoscaling.
Backend Laravel	Manipulación de payloads o parámetros críticos	Tampering	Movimientos inconsistentes o fraude	Validación server-side, idempotencia y logs de auditoría.
Backend Laravel	Operaciones sin rastro confiable	Repudiation	Dificultad para investigar reclamos	Audit logs, request-id y trazabilidad de negocio.
RDS MySQL	Acceso no autorizado o fuga de datos	Information Disclosure	Brecha de datos personales y financieros	RDS cifrado, SG restrictivos, TLS y rotación de secretos.
Redis	Exposición de caché o sesiones	Information Disclosure	Secuestro de sesión o filtración de saldos temporales	Redis privado, SG, TTL y minimización de datos en caché.
S3	Bucket o URL mal configurada	Information Disclosure	Exposición de comprobantes o KYC	Bloqueo de acceso público, SSE-KMS y URLs prefirmadas.
CI/CD	Inserción de código malicioso en pipeline	Elevation of Privilege	Compromiso del despliegue	OIDC, revisiones PR, branches protegidas y escaneo.
Integraciones externas	Respuesta alterada o abuso de API de terceros	Tampering	Cobros erróneos o inconsistencia operativa	Firmas, timeouts, retries controlados y observabilidad.
Consola e IAM	Permisos excesivos	Elevation of Privilege	Control total del entorno	Least privilege, Access Analyzer y revisión periódica.
SQS / colas	Reenvío o duplicación de eventos	Repudiation / Tampering	Pagos duplicados o notificaciones incorrectas	Idempotencia, DLQ y deduplicación lógica.

Cliente / frontend	Exposición de datos en tránsito	Information Disclosure	Intercepción o replay	HTTPS obligatorio, HSTS, cookies seguras y CSP.

7. Controles de seguridad por capa

IAM e identidad

- Root con MFA y uso exclusivamente de emergencia.
- Usuarios humanos a través de grupos/roles; workloads mediante task roles de ECS.
- Acceso CI/CD por OIDC, sin credenciales estáticas en el repositorio.
- Revisión trimestral de permisos y findings de IAM Access Analyzer.

Cifrado

- S3 con SSE-KMS para activos sensibles y evidencia.
- RDS MySQL cifrado en reposo y backups cifrados.
- Secrets Manager o Parameter Store SecureString para secretos de aplicación.
- TLS 1.3 en CloudFront/ALB; certificados gestionados por ACM.

Red y perímetro

- ALB expuesto solo en 443 y redirección obligatoria HTTP a HTTPS.
- Subred pública solo para ALB/NAT; tareas ECS en subred privada; datos en subred aislada.
- Security Groups por rol: ALB-SG, APP-SG, DB-SG, Redis-SG.
- AWS WAF con reglas administradas y límites por IP, URI y tamaño de request.

Aplicación y datos

- Validación de entradas, protección CSRF, gestión segura de sesiones y headers.
- Rate limiting en entrada y controles de negocio para repetición o idempotencia.
- Caché y sesiones en Redis con TTL acotado.
- S3 con acceso privado y URLs prefirmadas para descargas temporales.

Observabilidad y auditoría

- CloudTrail multi-región, logs cifrados y con retención >= 365 días.
- CloudWatch Logs / Metrics / Alarms para eventos técnicos y de negocio.
- GuardDuty para hallazgos de comportamiento anómalo y Security Hub para agregación.
- Inspector sobre imágenes ECR y revisión de dependencias de la aplicación.

8. Ejemplos técnicos de configuración

8.1 Política IAM mínima sugerida para la tarea ECS

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": ["ssm:GetParameter", "kms:Decrypt"],
      "Resource": [
        "arn:aws:ssm:us-east-1:<account-id>:parameter/platzi-wallet/prod/*",
        "arn:aws:kms:us-east-1:<account-id>:key/<kms-key-id>"
      ]
```

```
    },
    {
      "Effect": "Allow",
      "Action": ["s3:GetObject", "s3:PutObject"],
      "Resource": "arn:aws:s3:::platzi-wallet-private/*"
    },
    {
      "Effect": "Allow",
      "Action": ["logs:CreateLogStream", "logs:PutLogEvents"],
      "Resource": "arn:aws:logs:us-east-1:<account-id>:log-group:/ecs/platzi-wallet:*"
    }
  ]
}
```

8.2 Reglas base de seguridad para la red

```
ALB-SG   : inbound 443 desde Internet | outbound 80/9000 hacia APP-SG
APP-SG   : inbound 80/9000 solo desde ALB-SG | outbound 3306 a DB-SG y 6379 a Redis-SG
DB-SG    : inbound 3306 solo desde APP-SG
Redis-SG : inbound 6379 solo desde APP-SG
NACL     : deny explícito para puertos y rangos no autorizados en subredes sensibles
```

8.3 Reglas WAF iniciales recomendadas

```
- AWSManagedRulesCommonRuleSet
- AWSManagedRulesKnownBadInputsRuleSet
- AWSManagedRulesSQLiRuleSet
- Rate-based rule para IPs con abuso
- Size constraint rule para payloads anómalos
- URI allowlist para endpoints administrativos internos
```

9. Matriz de cumplimiento

El cumplimiento se plantea como soporte a la operación segura, no como promesa de certificación automática. La siguiente tabla resume el mapeo principal del plan:

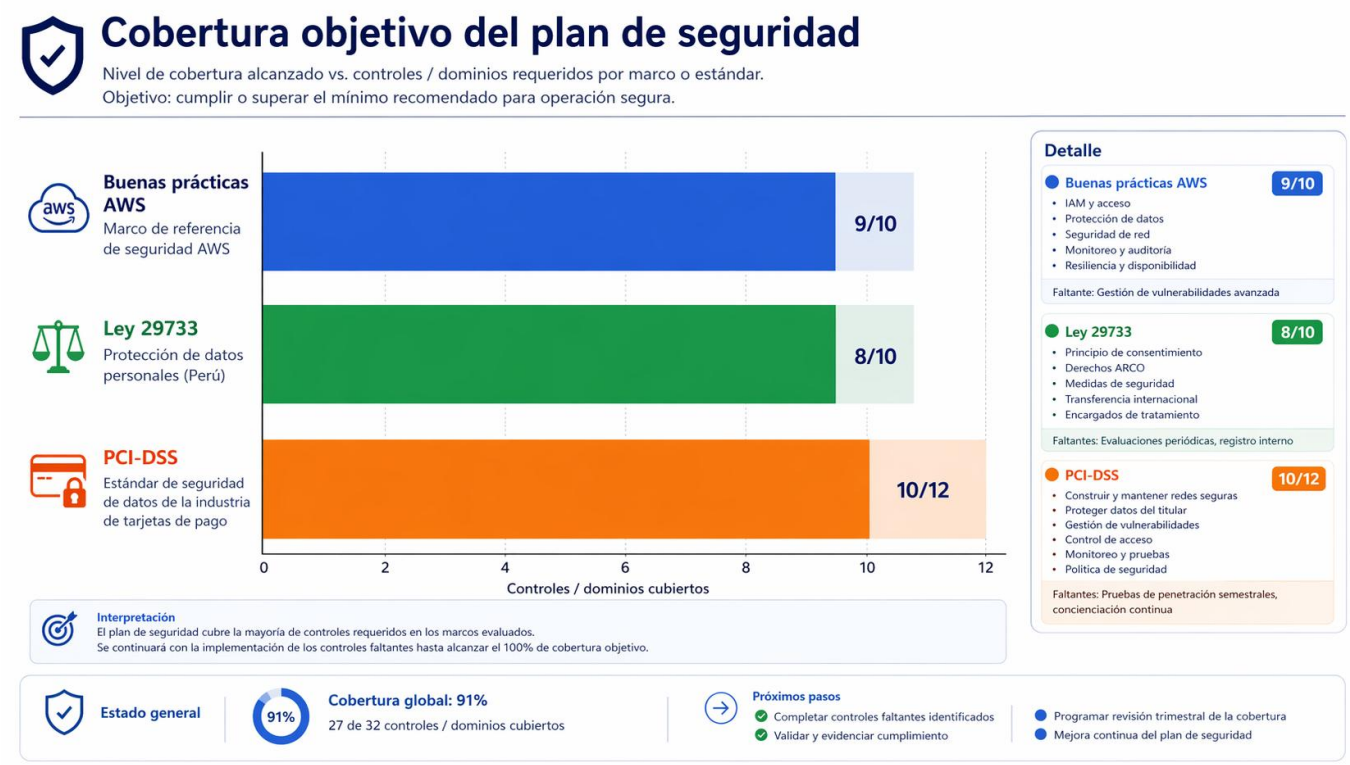

Figura 3. Cobertura objetivo del plan frente a marcos regulatorios y buenas prácticas.

Marco	Requisito / dominio	Cómo se cubre en Platzi Wallet	Estado objetivo
PCI-DSS	Control de acceso y autenticación	MFA, least privilege, segregación de funciones, logs y revisión de accesos.	Cubierto
PCI-DSS	Cifrado y protección de datos	TLS 1.3, KMS, RDS/S3 cifrados, secretos fuera del código.	Cubierto
PCI-DSS	Monitoreo y auditoría	CloudTrail, CloudWatch, GuardDuty, retención de logs y alertas.	Cubierto
Ley 29733 (Perú)	Protección de datos personales	Clasificación de datos, minimización, control de acceso, retención y trazabilidad.	Cubierto
Ley 29733 (Perú)	Consentimiento y tratamiento	Requiere controles de producto/proceso y registro del tratamiento; técnicamente soportado por trazabilidad y segregación.	Parcial controlado
Buenas prácticas AWS	Compliance as Code	Config, Security Hub, checklist productivo y revisión periódica.	Cubierto

10. Plan de respuesta a incidentes

La respuesta a incidentes se apoya en cinco fases: detección, contención, erradicación, recuperación y aprendizaje. El objetivo operativo es MTTD < 24 horas y MTTR < 4 horas para eventos críticos.

Figura 4. Flujo base de respuesta a incidentes.

10.1 Playbook: credenciales comprometidas

- Detectar hallazgo en CloudTrail, GuardDuty o IAM Access Analyzer.
- Revocar sesiones activas, deshabilitar credencial o rol afectado, rotar secreto y revisar acciones realizadas.
- Validar integridad de recursos modificados: task definitions, parámetros, buckets y políticas IAM.
- Reemitir credenciales temporales seguras, documentar el incidente y ejecutar post-mortem.

10.2 Playbook: posible brecha de datos en RDS

- Aislar origen de acceso, elevar el nivel de monitoreo y preservar evidencias.
- Rotar credenciales de base de datos y revisar conexiones, snapshots, exportaciones y rutas de acceso.
- Analizar impacto sobre datos personales y transaccionales; activar comunicación interna y legal según corresponda.
- Recuperar servicio, revisar controles compensatorios y reforzar monitoreo sobre tablas y consultas críticas.

10.3 Playbook: denegación de servicio o abuso masivo

- Correlacionar métricas de ALB, WAF y CloudWatch para confirmar el patrón del ataque.
- Aplicar reglas de WAF, rate limiting, bloqueo geográfico temporal y escalado del servicio si es necesario.
- Revisar errores 5xx, latencia y afectación a pagos, login y consultas de saldo.
- Cerrar el incidente solo tras estabilización sostenida y reporte de impacto.

11. Checklist de seguridad para salida a producción

IAM

✓ MFA habilitado en root y usuarios administrativos.

✓ No existen access keys persistentes en el pipeline.

✓ Task roles revisados por mínimo privilegio.

Cifrado

✓ RDS, S3, snapshots y logs cifrados.

✓ TLS obligatorio en endpoints públicos.

✓ KMS CMK definido para datos críticos.

Red

✓ ALB únicamente en 443.

✓ APP-SG solo recibe tráfico desde ALB-SG.

✓ DB y Redis no tienen exposición pública.

Detección

✓ CloudTrail multi-región activo.

✓ GuardDuty y Security Hub habilitados.

✓ Alertas críticas a canal operativo.

Datos y respaldo

✓ Backups automáticos probados.

✓ S3 versioning habilitado en buckets sensibles.

✓ Retención de logs y evidencia definida.

12. Hoja de ruta de hardening viable

1. Ola 1: IAM, MFA, secretos fuera del código, TLS, cifrado de RDS y S3, CloudTrail.
2. Ola 2: WAF, Security Groups definitivos, GuardDuty, CloudWatch alarms y dashboards.
3. Ola 3: revisión de dependencias, escaneo continuo, incident runbooks y pruebas de recuperación.
4. Ola 4: automatización de cumplimiento, evidencia operativa y mejora continua.

13. Conclusión

El plan de seguridad propuesto protege Platzi Wallet sin romper la continuidad técnica del proyecto. Se basa en controles viables y profesionales para la arquitectura AWS ya seleccionada, refuerza identidad, red, cifrado, auditoría y respuesta a incidentes, y deja una base sólida para operación segura, evidenciable y progresivamente más madura.

Fuentes de apoyo utilizadas

- Sesión 05 - Seguridad en la Nube: IAM, Encryption, Compliance y Zero Trust Architecture.

- Guía de cloud computing para empresa, con secciones sobre seguridad, riesgos, aspectos legales y checklist de contratación.
- Sesión 04 - Migración a la Nube: estrategias, herramientas y mejores prácticas.
- Documentos previos del proyecto Platzi Wallet: diseño del sistema, comparativa cloud e implementación en AWS.